

PlugSure CSMS v1.3.0: ready for a supervised pilot, not yet for public paid charging

Reviewed 28 Sep 2026 Build v1.3.0 (final) Baseline v1.2.1 Stack Node 24 • PostgreSQL 18 (target 16)

The platform is feature-complete for operating a charging network. Every automated suite passes on the production-shaped split deployment. Two provider accounts stand between it and a public launch: a contracted QRIS acquirer and an SMS/WhatsApp provider for driver sign-in codes. The integrations for both are built — the credentials are entered under Govern → Integrations.



DONE

Lab verified

All suites green against simulated OCPP 1.6 and 2.0.1 chargers, with row-level security enforced.



NEXT

Supervised pilot

After the acceptance test on a real charger, TLS and alert channels are set up. RFID and fleet cards work fully.



BLOCKED • 2 ACCOUNTS

Public paid launch

Needs the operator's QRIS acquirer contract and a WhatsApp/SMS account, entered in Integrations and tested.

What was run

541/541 Unit and database tests	147/147 Field-conditions end-to-end	96/96 Console end-to-end	125/125 Driver app end-to-end, incl. map, push, reservations, reservation fees and the queue	170/170 Roaming (OCPI) end-to-end, both roles, incl. partner smart charging and hubs
453/453 Bidirectional charging over OCPP 2.1, signed meter values (OCMF), white-label driver apps with iOS notifications (APNs, badges, rich notifications) and Live Activities, API, sandbox on OCPP 1.6 / 2.0.1 / 2.1, TypeScript SDK and per-key rate limits, fleet billing (credit notes, PDFs, customer portal), promotions, Plug & Charge, onboarding, integrations, e-wallet & card payments, card holds & saved cards, linked e-wallets and post-pay end-to-end, incl. 75 live responses checked against the spec				

The end-to-end suites run the API and gateway as separate processes and connect as the non-superuser `plugsure_app` role, so tenant isolation is tested as it runs in production. The field suite drives raw OCPP frames so the "charger" can misbehave the way real hardware does: ground faults, dropped connections, power loss, offline transactions uploaded later, duplicate frames, meter resets, a clock three days fast, and two drivers racing for one connector. The push-notification suite runs against a mock push service. The mock decrypts every message with the test phone's own keys and checks the VAPID signature. Typecheck is clean in both configurations. Migrations 001–041 apply cleanly and re-run as a no-op.

Readiness by capability

● ready · ● partial · ○ not built

AREA	STATUS	EVIDENCE	OPEN ITEMS
OCPP 1.6J, 2.0.1 and 2.1	● Ready	Security profiles 0–3; 2.0.1 commands translated per version; device events accepted, and cleared events resolve their alert. 2.0.1 device model in the console: reports stored as they arrive, variables set after checking the station's own limits (security and network settings refused), read on demand, and variable monitors added, listed and removed. OCPP 2.1 as its own protocol, with the car's ISO 15118 charging needs recorded per session.	Check each 2.0.1 and 2.1 model on the bench; vendors differ in what they expose.
Bidirectional charging (V2G / V2B)	● Ready	ISO 15118-20 cars give energy back over OCPP 2.1 during a site's programme hours, with the driver's or the fleet's consent. It stops at the battery floor, an hour before departure, and on withdrawal. By default it is capped at the site's own auxiliary load, so nothing flows back to PLN. The driver's credit comes off the session before tax. DC_BPT and AC_BPT also run end to end against the sandbox's virtual 2.1 chargers. End-to-end 21/21 and 17/17.	Bench-test each car and charger pair; AC bidirectional not yet tried on hardware. Not built, waiting on a PLN or DSO grid code or a market: grid-support (DER) functions, price schedules to the car, and selling exported energy (PLN is the single buyer, so the credit is the operator's own). Export only with a PLN agreement.

AREA	STATUS	EVIDENCE	OPEN ITEMS
Signed meter values (OCMF)	Ready	Meter-signed readings from OCPP 1.6 (SignedData) and 2.x (signedMeterValue) are verified (ECDSA P-256) against the meter key registered on the connector, then checked against the billed kWh and the meter serial. Each session is verified, unverified key, mismatch, invalid, incomplete or missing. Per site: record (warn) or require (park before invoicing). Shown on the receipt, in the driver app and the console, with an XML file for the Transparency Software and OCPI <code>signed_data</code>. A 1.6 billing bug (a signed sample read as NaN) was fixed. End-to-end 20/20.	Register each meter's public key; switch signing on per 2.x charger (1.6: vendor key). Only OCMF is verified.
Field robustness	Ready	Field suite cases 1–19: offline transactions, retries, meter reset, clock skew, reboot.	Confirm on real hardware.
Remote operations, config, FOTA, diagnostics	Ready	Cockpit, 45-key config studio, firmware campaigns through to Verified, log upload viewer.	—
Load management	Ready	PLN kVA × PF ceiling guardrail (422 above it), genset curtailment, connector priority.	—
Tariffs and tax receipts	Ready	Flat, ToU (WBP/LWBP), tiered, idle fee. Receipt shows DPP 11/12, PPN 12 %, PBJT-TL, checked to the rupiah.	—

AREA	STATUS	EVIDENCE	OPEN ITEMS
Payments: QRIS, e-wallets, cards	🕒 Needs account	Midtrans, Xendit and bank-direct (BI-SNAP) adapters, set in the console per operator; payments confirmed only by signed notifications, captured once and in full; refunds through the acquirer; switching acquirer keeps the old account for its payments. New: GoPay, ShopeePay, OVO, DANA, LinkAja and cards beside QRIS for charges and passes, chosen per operator. The same pre-purchase model applies; cards are paid on the acquirer's hosted 3-D Secure page, so card numbers never reach PlugSure. New: card holds (pre-authorisation: the rated total is captured and the rest released, with automatic retries and a console list; a hold that expired at the acquirer before capture ends at once with a critical alert, “expired, not charged” and the amount to collect in the console, and the driver paying it from the receipt in the app with any offered method, a second payment refunded) and saved cards (acquirer tokens only, one tap, bound to the driver and the acquirer account; a card whose token has ended at the acquirer refused with a message naming it and no longer offered). New: linked GoPay (Midtrans or Xendit), OVO, DANA, ShopeePay and LinkAja (Xendit): link once, pay in one tap, unused balance refunded automatically, or optionally post-pay: the rated total charged after the session, with a limit, balance checks for GoPay, OVO, DANA, ShopeePay and LinkAja where the acquirer reports them (for GoPay at Midtrans the wallet or GoPay Tabungan, never PayLater credit, with the token looked up again before each charge, and a GoPay, OVO, DANA, ShopeePay or LinkAja link the driver ended in	P0: the acquirer contract and credentials (with each e-wallet and card channel enabled on the account activated, plus card pre-authorisation, saving and e-wallet tokenisation if used), and a test in its sandbox. Xendit's v3 hold, token and e-wallet balance fields must be confirmed in its sandbox.

AREA	STATUS	EVIDENCE	OPEN ITEMS
		the e-wallet app (or that expired) refused with “link it again” rather than a balance message, and an unpaid session (link ended, insufficient balance, waiting for the PIN, or the PIN expired, denied or cancelled) payable in the app with another method, shown on the home screen with Web Push reminders, their tax receipt a nil transaction until paid; Xendit link callbacks end or activate links at once, a second payment refunded; optionally post-pay only when checked), and collection of unpaid sessions. Tested 21/21 + 21/21 + 26/26 + 19/19 + 40/40 against provider fakes and real OCPP sessions.	
Driver sign-in (OTP)	🕒 Needs account	Codes by WhatsApp (Meta Cloud API), Twilio, Zenziva or your own gateway, with an SMS fallback, set in the console; fleet PIN flows with brute-force lockout.	P0: a WhatsApp Business sender with an approved authentication template, or an SMS account.
Refunds	• Ready	Unused balance and never-started payments queued; pay via provider or record a bank transfer; no double refund.	"Refund via provider" depends on the acquirer's API.
Availability and alerts	• Ready	Outage history and uptime report, with per-site offline thresholds; e-mail, WhatsApp and SMS routing with quiet hours, escalation and acknowledge; on-call rotas with overrides; WhatsApp delivered/read/failed from Meta's signed webhook, with SMS fallback. Field suite 24b.	Set up the Meta webhook; an SMS account with a registered sender for the fallback.
Webhooks	• Ready	HMAC-signed, outbox with ~11 h retry, replay, SSRF guard checked at connect time.	—
Platform commission statements	• Ready	Base excludes PBJT and PPN (cross-checked); 8 / 6.5 / 5 % tiers; AC Rp 150,000 and DC Rp 350,000 minimums; finalised months frozen.	Statement is not a faktur pajak.

AREA	STATUS	EVIDENCE	OPEN ITEMS
Owner portal and Billing	Ready	Read-only owner login scoped to its own sites; per-owner shares that add up; reviewed on phone and tablet, light and dark.	Split settlement depends on the payment gateway.
Driver app (PWA)	Ready	Find, pay, charge, stop, tax receipt; station map with nearby stations grouped; favourites; Web Push notifications; 15-minute connector reservations (ReserveNow), with an optional fee per site paid in the app or on the fleet invoice; a first-come-first-served queue at busy sites, with the freed connector held for the next driver; partner network for roaming fleet cards, with reservations there too; phone, tablet and two-column layouts; WCAG AA in both themes.	Own or commercial map tile service before real traffic; reservations and queue holds checked per charger model.

AREA	STATUS	EVIDENCE	OPEN ITEMS
White-label driver apps	🔴 Needs store accounts	Each operator can run its own driver app (Commercial → Driver app): PlugSure's app under the operator's name, tagline, colours (the accent adjusted per theme so text always reads at 4.5:1 or more) and icon (every launcher, maskable and App Store size made from one PNG), with its support contacts. It shows only the operator's stations, and another operator's charger is named and refused before payment. Drafts are previewed live in the console. A live app runs on the operator's own web address, with an on-demand certificate and the Android and iOS association files. A build kit holds the Play Store app (Trusted Web Activity, Bubblewrap, CI workflow), the App Store shell (Capacitor), icons, listings and data-safety answers. The iOS app gets native notifications through the operator's APNs key (checked with Apple from the console; development tokens found automatically; uninstalled apps dropped), with a badge counting unpaid sessions, buttons (stop, receipt, pay, give up a queue turn, cancel a reservation), time-sensitive queue turns and a picture of the finished charge. Live Activities show a charge under way on the lock screen and in the Dynamic Island, started by the app or by PlugSure (iOS 17.2+), updated within Apple's budget and ended with the cost. End-to-end 28/28, 20/20 and 14/14.	The operator's Google Play and Apple developer accounts, signing keys and a build from the kit (no store build made in testing; APNs tested against a stand-in, not a real iPhone; the Swift files for buttons, pictures and Live Activities not compiled here). Update Caddy (on-demand TLS) and run <code>caddy validate</code>.

AREA	STATUS	EVIDENCE	OPEN ITEMS
Fleet invoicing and e-Faktur	Ready	Fleet accounts with NPWP/NITKU; monthly invoices per company with PPN 12% on DPP nilai lain per site line (agrees with the session receipts), partner networks re-billed at cost; numbering, PDF invoices, e-mail, payments, void and re-issue without double billing; credit notes with the tax split per line (reducing what is owed, refunded, or off the next invoice); Coretax bulk-import XML (code 04); a fleet customer portal (invoices, credit notes, this month, cards, block a lost card) scoped to its own account. End-to-end 53/53 on real OCPP sessions.	Confirm the e-Faktur item classification with a tax adviser and test one import into Coretax. Portal users must be able to reach the console address. Credit notes need a nota pembatalan in Coretax by hand.
Promotions and memberships	Ready	Discounts applied before PBJT-TL and PPN as receipt lines, the cheapest allowed combination per session; membership plans (member price, % off, included kWh, no service fee) for fleets on the monthly invoice (billed by the day for part of a month) with its own e-Faktur line, and for drivers as 30-day passes that can renew automatically with a saved card or linked e-wallet and switch plans with the unused days credited; promotions with codes, happy hours, audiences, per-customer limits and budgets; loyalty points earned per session and spent before tax. End-to-end 24/24 and 38/38 on real OCPP sessions.	Passes need the live acquirer; unattended renewal needs saved cards or linked e-wallets on (and saved-card 3-D Secure off on Midtrans). Book the loyalty liability.

AREA	STATUS	EVIDENCE	OPEN ITEMS
Onboarding and charger certificates	Ready	Onboarding page (chargers in progress with the reason a handshake was refused, certificates, CA) and wizard for the hardware details; Security Profile 3 certificates issued automatically by PlugSure's CA — generated, from the charger's CSR, or zero-touch over OCPP — and renewed without lock-out. Real mTLS connections tested; 19/19.	Put the CA on the TLS terminator and update Caddy (a header-spoofing fix); no PKCS#12; 2.0.1 profile raise stays manual.
ISO 15118 Plug & Charge	Ready	CSMS side over OCPP 2.0.1 and 1.6 (DataTransfer): contract authorisation with chain checks and OSCP, then the contract as a card; chargers' V2G certificates signed, delivered and renewed; trust anchors installed; every exchange logged. Test PKI and sandbox simulation for developers. End-to-end 37/37.	Needs a V2G PKI provider (Hubject or similar) behind the PKI gateway, and 15118 firmware on the chargers.
Integrations	Ready	Govern → Integrations: the payment acquirer (QRIS, plus the e-wallets and cards the operator enables), sign-in codes, the Plug & Charge PKI and map tiles, with encrypted write-only secrets, connection tests, an activity log and audit; environment variables as fallback.	Provider accounts are the operator's to open.

AREA		STATUS	EVIDENCE	OPEN ITEMS
BLOCKERS	Integration API and • Ready		OpenAPI 3.1 (266 operations, 11 webhook events, permissions per operation) with a "Try it"	SDKs in other languages via standard OpenAPI generators; rate limits are
	Before public paid charging			
P0 • PAYMENTS			P0 • DRIVER SIGN-IN	
Live QRIS acquirer			SMS / WhatsApp OTP provider	
A contract and credentials from Midtrans, Xendit or a bank (SNAP). The integration is built: enter them under Govern → Integrations, paste the notification URL into the acquirer's dashboard, tick the e-wallets and cards activated on the account (and card holds / saved cards / e-wallet linking if enabled there), and make one small real payment with each, plus one hold captured after a real session.			Without it, drivers cannot sign in in production. The integration is built (WhatsApp Cloud API, Twilio, Zenziva or your gateway, with a fallback): connect the account and send yourself a test code. A pilot can run on fleet cards with console-issued PINs meanwhile.	
			meter, and on 2.1 a car that gives	
			energy back (DC_BPT / AC_BPT).	
CHECKLIST			Event simulation, isolated from	
Before the pilot goes live			live data, the driver app and	
			roaming. End-to-end 38/38,	
01	Run <code>docs/ACCEPTANCE-v1.3.md</code> on at least one real charger. The simulator proves the protocol path, not the hardware.		Field ops	
02	TLS and OCPP Security Profile 2 behind Caddy; console hostname behind an IP allow-list.		Infra	
03	Set <code>INTERNAL_API_TOKEN</code> , <code>SECRETS_KEY</code> , <code>PUBLIC_BASE_URL</code> , <code>OCPP_PUBLIC_URL</code> ; mount persistent <code>STORAGE_DIR</code> .		Infra	
04	Alert channels: your own SMTP account, a WhatsApp Business sender and an approved Utility template, and the Meta webhook (callback URL, verify token, app secret) for delivery status. For SMS fallback, an SMS account with a registered sender. Set up on-call rotas. Send a test to every contact.		Ops	
05	Create the operator admin and the platform billing account (<code>create-admin --platform-admin</code>); change every one-time password.		Admin	
06	Driver app: point <code>MAP_TILE_URL</code> at your tile service, allow the gateway outbound HTTPS to the push services, and reserve once on each charger model in use.		Infra	
07	Fleet billing: seller NPWP/NITKU and the e-Faktur item classification confirmed with the tax adviser; each fleet company's NPWP and billing e-mail entered; one test XML imported into Coretax. If fleet memberships are invoiced, the membership-fee item confirmed too. If fleet customers use the portal, publish the console address for them (the supplied Caddyfile allow-lists it to the office).		Finance	
08	Charger certificates: download the CA from Onboarding → Certificate authority to Caddy, enable <code>client_auth</code> , and update Caddy from <code>deploy/Caddyfile</code> (it now overwrites <code>X-Client-Cert-Fingerprint</code>).		Infra	
09	Plug & Charge (if used): PKI provider onboarded behind the PKI gateway; trust anchors fetched and installed; every 15118 charger has its V2G certificate; one test contract charged per charger model.		Infra	
10	Take a database backup and rehearse a code rollback. Migrations are forward-only.		Infra	
11	Expect a burst of offline alerts after upgrading, for chargers that were already quietly offline. Decommission units that are gone.		Ops	

FINDINGS

Defects found and fixed during v1.3

Each of these was found by testing or review in this release cycle and is fixed in the delivered package. Several would have failed silently in production.

SEVERITY	DEFECT	EFFECT BEFORE THE FIX
HIGH · OPS	Split deployment could not command any charger	Every console command failed and every charger showed offline in the standard compose and systemd setup.
HIGH · OPS	Background workers never ran in production	No load management loop, no tera-lapse blocking, no reconciliation.
HIGH · REVENUE	Paid QRIS claim tokens never expired	A screenshot of a paid QR could start unlimited free sessions.
HIGH · 2.0.1	Prepaid cut-off and DLM sent <code>transactionId: NaN</code>	Stations kept charging past the amount paid; site ceilings could be exceeded.
HIGH · MONEY	Refunds promised but never paid	Unused balances and never-started payments sat in <code>captured</code> forever.
HIGH · PRIVACY	Owner portal showed drivers' full RFID numbers	An owner could clone a fleet card; partial search allowed rebuilding numbers digit by digit.
HIGH · SECURITY	One-time passwords worked indefinitely through the API	An invite password shared over chat stayed valid until someone used the console.
MEDIUM · SECURITY	Fleet PIN had no attempt limit, and v1.3 PINs never verified	Brute-forceable, and no card with a console-issued PIN could sign in.
MEDIUM · ACCESS	Site Hosts got 403 on their own sites	Site-scoped users could not use the console.
MEDIUM · ACCESS	Ocpp log readable by site-scoped read-only users	Exposed RFID idTags in raw frames.
MEDIUM · INTEROP	Routine 2.0.1 messages refused	NotifyEvent, NotifyReport, MeterValues and ReservationStatusUpdate got NotImplemented.
MEDIUM · SECURITY	Firmware checksum verification fetched any URL	Could be pointed at the cloud metadata endpoint or internal services, directly, by DNS rebinding or by redirect.
MEDIUM · BILLING	Tariff writes not atomic	Concurrent assigns duplicated rows; a failed save left a tariff missing prices that could under-bill.
LOW · API	Malformed ids and commands to offline chargers answered 500	Integrations could not tell their own mistake or an offline charger from a server fault; now 400 and 409.
LOW · OPS	Re-running the seed duplicated or deleted data	Extra copies of the demo site and API keys; every tariff in the org deleted, including the operator's own.
LOW · AUDIT	Audit-chain tests silently failing since v1.2	Tamper-evidence was untested; the tests now prove the database refuses the attacks.

OPERATIONS

Limits to plan around

Payments and drivers

- A driver has **30 minutes** after paying to start. After that the QR stops working and the full amount is refunded.
- A prepaid top-up reserves a worst-case idle allowance. With a steep idle fee a small top-up buys little energy (Rp 20,000 bought 99 Wh at Rp 1,000/min). Keep idle fees moderate on prepaid-heavy sites.
- The commission statement is not a tax invoice. Issue the faktur pajak separately.
- The station map uses OpenStreetMap's own tile server by default, which is for light use only. Set `MAP_TILE_URL` to your own or a commercial tile service. On iPhone, notifications need the app added to the Home Screen.

Alerts and integrations

- The offline threshold defaults to `OFFLINE_ALERT_MINUTES` (15); sites with weak signal can set their own.
- Without the Meta webhook, WhatsApp "sent" only means accepted by WhatsApp. With it, delivered, read and late failures show, and failures can fall back to SMS. `/hooks/*` must be public (the supplied Caddyfile does this). Meta charges per Utility conversation; SMS per message.
- Webhooks and alerts are sent by the gateway's workers. With `RUN_WORKERS=false` on every gateway, nothing is sent.

POSITION

Against commercial platforms

Stronger for Indonesia

- PLN kVA × PF ceiling guardrail and genset curtailment
- Tera and SLO compliance vault that blocks lapsed connectors
- PPN 12 % × DPP 11/12 and PBJT-TL receipts
- QRIS-first payment
- Alerts over WhatsApp, the channel operations teams use
- Bidirectional charging that covers the site's own load and never exports to PLN without an agreement

Behind ChargePoint, Driivz, AMPECO, Monta

- White-label app builds per operator

Sources in the v1.3.0 package: `RELEASE-NOTES-v1.3.0.md` , `docs/GAP-ANALYSIS-v1.3.md` , `docs/ACCEPTANCE-v1.3.md` and the deployment guide. Test counts are from the runs of 27–28 September 2026.